

访问控制漏洞报告（Lab1：未受保护的管理员功能）

1. 漏洞名称

访问控制失效（Broken Access Control） — 敏感信息泄露与未授权访问

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站的管理员后台未做有效的访问控制校验，且敏感路径直接暴露在 robots.txt 文件中。攻击者可以通过查看 robots.txt 发现隐藏的管理后台路径（/administrator-panel），直接访问该路径后，能够绕过身份验证直接执行高危操作（如删除系统用户）。

4. 漏洞位置

信息泄露路径：GET /robots.txt

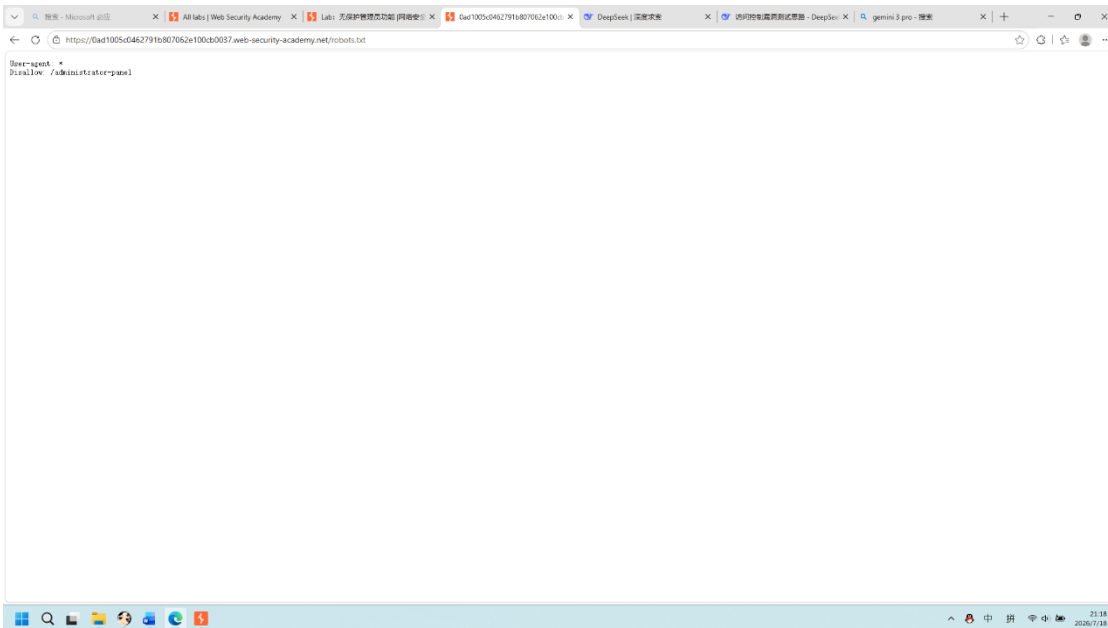
未授权访问路径：GET /administrator-panel

5. 漏洞复现过程

第一步：信息收集与发现敏感路径

访问网站首页，检查站点的 robots.txt 文件（搜索引擎爬虫协议）。

图 1：发现 robots.txt 中的敏感路径

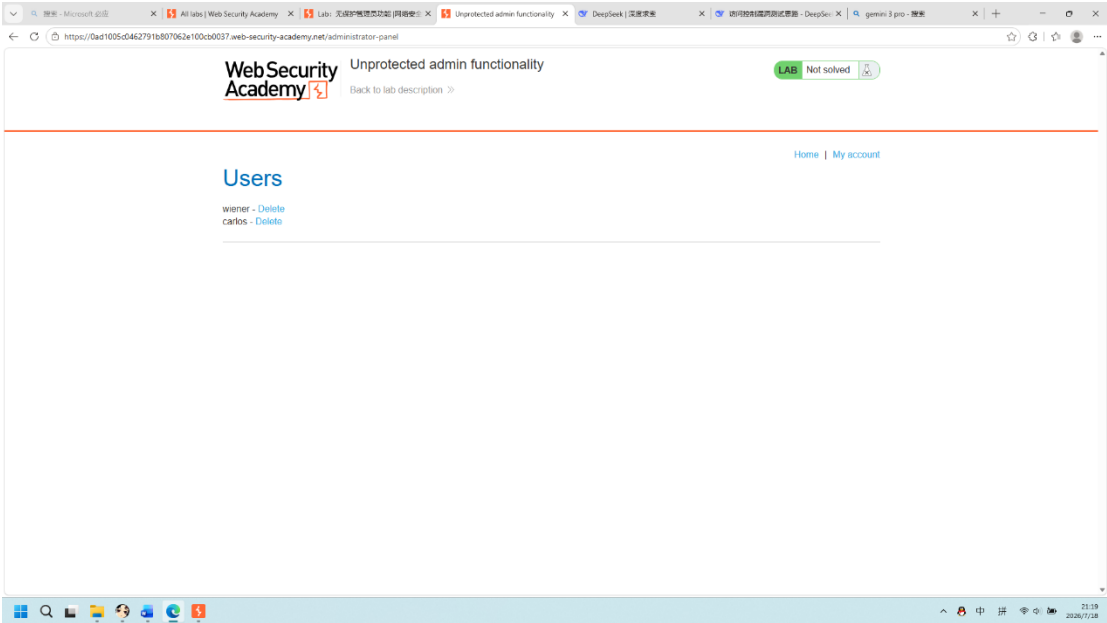


说明：通过查看 robots.txt，发现管理员后台被配置为禁止爬虫访问，但这反而暴露了后台路径。

第二步：访问未受保护的管理后台

将 URL 路径从 /robots.txt 改为 /administrator-panel，直接访问该隐藏路径。

图 2：成功访问管理员控制台

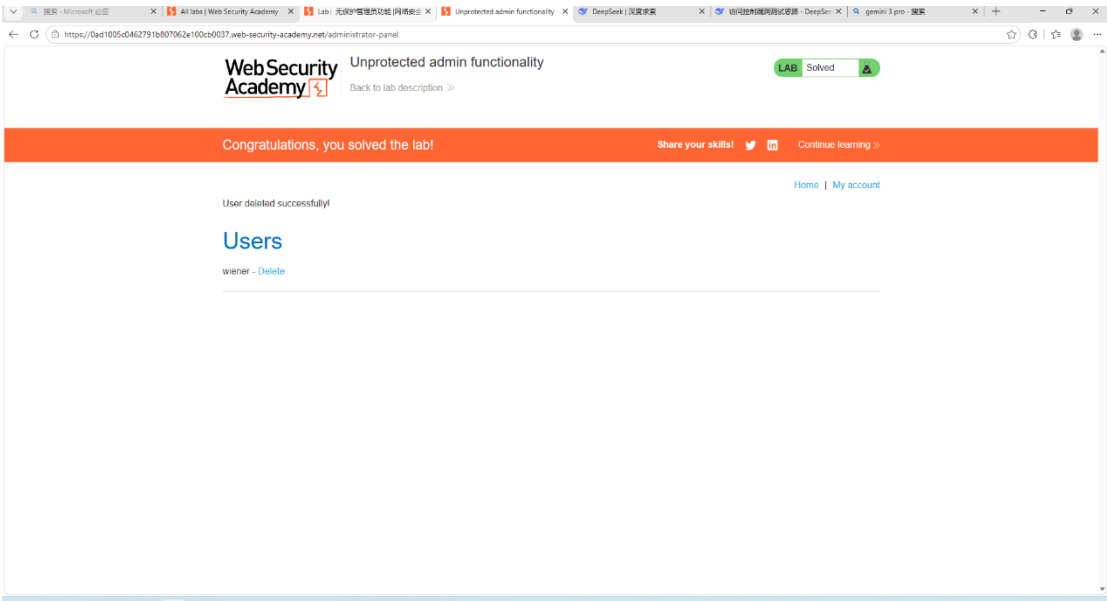


说明：由于后台未进行有效的身份校验，直接访问该路径即可加载管理控制台，证明访问控制失效。

第三步：执行未授权删除操作

在管理界面找到用户 carlos，点击其对应的 Delete（删除）按钮，发起删除请求。

图 3：成功删除目标用户并解决实验



说明：成功以非管理员身份删除了目标用户 carlos，验证了未授权访问的破坏性。

6. 漏洞原理

该漏洞属于不安全的直接对象引用（IDOR）和缺失功能级别访问控制。

1. 开发者将后台路径 /administrator-panel 写在 robots.txt 中意图阻止搜索引擎收录。
2. 后端代码没有对访问 /administrator-panel 的请求进行会话（Session）或角色（Role）验证。
3. 导致任何知道该路径的未授权访问者，都可以直接加载管理员功能界面并执行敏感操作。

7. 漏洞影响

- 攻击者可轻易发现并绕过访问控制，直接进入系统后台。
- 造成敏感数据泄露（如当前所有用户的列表）。
- 可直接执行破坏性操作：删除所有用户、修改配置、甚至获取系统 Shell。

8. 修复建议

- ① 移除敏感路径信息：切勿在 robots.txt 中暴露 /admin、/administrator-panel 等未授权路径。
- ② 实施严格的访问控制验证：在管理后台的路由入口处，必须强制校验当前用户的 Session 和 Role 权限，未登录或权限不足者直接返回 401 Unauthorized 或 403 Forbidden。
- ③ 隐藏后台入口：避免使用默认或容易猜解的路径（如 /admin），应使用不可预测的随机字符串作为管理员入口。

9. 工具

- Google Chrome / Firefox 浏览器（直接修改 URL 路径）
- PortSwigger Web Security Academy（靶场平台）